

TECHNICAL DESIGN & MODELING PACKAGE

# System Architecture & UML Specification

## OneLogin – Single Sign-On Rollout Across a University's Applications

Comprehensive structural and behavioral modeling package supporting the Software Requirements Specification. Specifies the formal technology stack, physical infrastructure tiers, flow-oriented architecture, complete Use Case hierarchy, high-cohesion class structure with loose coupling justification, distributed 3-application sequence flows, password reset activity logic, and deterministic session state machines.

### Document Control

|                      |                                                                                                  |
|----------------------|--------------------------------------------------------------------------------------------------|
| Document Title       | System Architecture & UML Design Package — OneLogin SSO                                          |
| Document Version     | Version 1.0 (Baseline)                                                                           |
| Standard Followed    | OMG Unified Modeling Language (UML) 2.5 Specification                                            |
| Status               | Approved Design Baseline for Integration, Verification, and Scheduling                           |
| Related Deliverables | SRS Document, Project Plan, Estimation Sheet, Test Plan & Evidence, Risk Register & Closure Note |
| Protocol Baselines   | SAML 2.0 Web Browser SSO Profile, OpenID Connect Core 1.0 over OAuth 2.0                         |

### Formal Sign-Off & Approvals

| Role                | Designation & Stakeholder | Signature | Approval Date |
|---------------------|---------------------------|-----------|---------------|
| Project Sponsor     | Vice-Chancellor           | _____     | 02 Oct 2026   |
| Business Owner      | IT Head                   | _____     | 02 Oct 2026   |
| Project Manager     | Lead SEPM Consultant      | _____     | 02 Oct 2026   |
| Technical Architect | Lead Systems Engineer     | _____     | 02 Oct 2026   |

**Architectural Traceability Policy:** Every diagram in this specification traces directly to functional requirements FR-01 through FR-11 and non-functional requirements NFR-01 through NFR-06. The architecture isolates the core identity provider from individual university applications via standardized adapter contracts.

Document Outline & Table of Contents

This document provides the formal architectural baseline for the OneLogin Single Sign-On implementation. Below is the structural outline of all modeling views, design patterns, diagrams, and technical justifications.

Document Control & Sign-Off Approvals

— Authoritative governance and sign-off

Page 1

Document Outline & Architectural Index

— Structural roadmap and diagram inventory

Page 2

1. Technology Stack & Implementation Architecture

— 4 concrete tiers, frameworks, storage, runtime decoupling

Page 3

2. System Architecture & Authentication Flowchart

— End-to-end credential gating and federated flow

Page 4

3. Use Case Model & Actor Hierarchy

— 5 university roles, boundary services, and FR mappings

Page 5

4. Class Diagram & Static Structure

— Object-oriented classes, Adapter pattern, methods and attributes

Page 6

5. Architectural Cohesion & Loose Coupling Justification

— Written analysis, SRP defense, and NFR-06 proof

Page 7

6. Sequence Diagram: Cross-Application SSO Flow

— "Log in once and access three applications" (FR-02, TC-03)

Page 8

7. Activity Diagram: Self-Service Password Reset

— SSPR verification lifecycle, 15-min OTP, password rules (FR-07)

Page 9

8. State Machine Diagram: User Session Lifecycle

— Deterministic session transitions, 30-min idle timeout, logout

Page 10

List of Architectural Figures & Models

| Figure / Model | Model Title                 | Diagram Type                 | Primary Traceability        |
|----------------|-----------------------------|------------------------------|-----------------------------|
| Figure 2.1     | Authentication Flowchart    | Behavioral Flow Architecture | FR-01, FR-08, FR-11         |
| Figure 3.1     | Unified Use Case Diagram    | OMG UML Use Case Model       | FR-01 through FR-11         |
| Figure 4.1     | Structural Class Hierarchy  | OMG UML Class Diagram        | NFR-06 (Loose Coupling)     |
| Figure 6.1     | 3-App Cross-Login Sequence  | OMG UML Sequence Diagram     | FR-02, TC-03 (Single Login) |
| Figure 7.1     | Self-Service Password Reset | OMG UML Activity Diagram     | FR-07, TC-10, TC-11         |
| Figure 8.1     | User Session State Machine  | OMG UML State Machine        | FR-02, FR-08, FR-09         |

**Document Completeness Notice:** All diagrams are authored in high-contrast SVG vector graphics conforming to OMG UML 2.5 standards, with clear structural outlines, explicit directional connectors, and typed parameter signatures.

# 1. Technology Stack & Implementation Architecture

To realize the functional and non-functional targets of the SRS (including sub-2.0s login response time under NFR-03, 99.9% availability under NFR-01, and cryptographically secure salted hashes under NFR-02), the OneLogin SSO implementation is architected across four concrete technology tiers.

| Architectural Tier | Component / Technology                                 | Version / Specification   | Architectural Responsibility & Rationale                                                                          |
|--------------------|--------------------------------------------------------|---------------------------|-------------------------------------------------------------------------------------------------------------------|
| Edge & Ingress     | NGINX Plus / HAProxy                                   | v1.26+ (L7 Reverse Proxy) | TLS 1.2/1.3 termination, HTTP/2 multiplexing, active-standby virtual IP routing, and DDoS rate-limiting.          |
| Core IdP Backend   | Java 21 LTS / Spring Boot 3.3<br>(Spring Security 6.3) | JVM Enterprise Runtime    | Executes authentication business logic, SAML 2.0 assertion signing, OIDC token issuance, and password policies.   |
| Federation Crypto  | Bouncy Castle Crypto APIs                              | v1.78+ (FIPS 140-2 ready) | 2048-bit RSA / ECDSA digital signatures, XML encryption, SHA-256 digests, and Argon2id/bcrypt key derivation.     |
| Session Cache Tier | Redis Clustered Sentinel                               | v7.2+ In-Memory Store     | Distributed, low-latency (<2ms) session store; tracks 30-min idle timeouts (FR-09) and Single Logout (FR-02).     |
| Identity Directory | OpenLDAP / Active Directory                            | LDAPv3 (RFC 4510)         | Authoritative user repository; stores university credentials, group DNs, mobile numbers, and secondary emails.    |
| Audit Storage      | PostgreSQL                                             | v16+ (Append-only tables) | Immutable, encrypted-at-rest storage for audit events (FR-10) with 12-month retention and automated log rotation. |
| Front-End UI       | HTML5, Tailwind CSS, Vanilla JS                        | Modern Responsive Web     | Lightweight, dependency-free login form, application launcher, and accessible self-service password reset views.  |

## 1.1 Database Schema & Storage Architecture

The system isolates mutable operational states from the authoritative directory to prevent locking and schema corruption:

- OpenLDAP (Directory Tier):** Holds canonical user identities (``uid``, ``cn``, ``mail``, ``telephoneNumber``, ``userPassword`` stored exclusively as salted hashes, and ``memberOf`` role groups). Read-heavy with strict SSL/TLS LDAPS (port 636) connections.
- Redis (Distributed Session Store):** Key-value store holding ephemeral session tokens (``session:{token_id} -> {user_id, role, created_at, last_active, authorized_apps}``). Configured with a 1,800-second (30-minute) TTL that automatically slides upon user activity.
- PostgreSQL (Audit Sink):** Relational schema with append-only permissions containing ``id``, ``user_id``, ``event_type`` (LOGIN\_SUCCESS, LOGIN\_FAIL, LOCKOUT, UNLOCK, SSPR\_REQUEST, SSPR\_SUCCESS, ROLE\_CHANGE), ``ip_address``, ``target_sp``, and ``timestamp``. Zero secret values or passwords are ever stored.

**Runtime Decoupling Guarantee:** Downstream university applications (ERP, LMS, Library) connect exclusively over standard HTTPS network interfaces. They do not share databases, JVM heaps, or file system mounts with the IdP core.

## 2. System Architecture & Authentication Flowchart

The OneLogin Single Sign-On (SSO) architecture functions as a centralized Identity Provider (IdP) mediating access between user browsers and the university's 12 application endpoints. The flowchart models end-to-end credential verification, brute-force lockout threshold checks (FR-08), privileged MFA gating (FR-11), and federated token issuance.

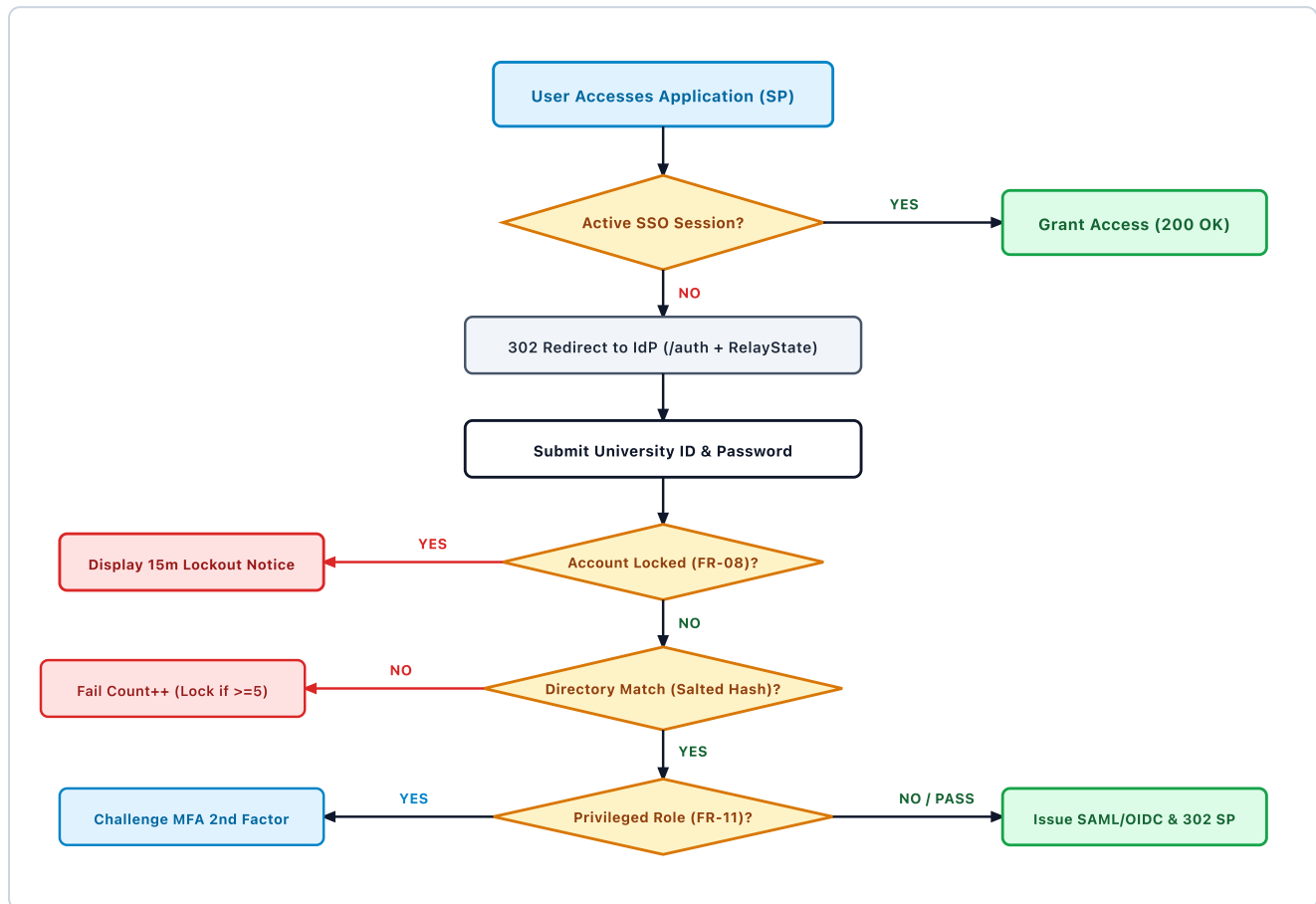


Figure 2.1: OneLogin Central Authentication and Security Gate Flowchart.

**Security Enforcement:** Centralizing verification at the IdP guarantees that downstream application servers never touch primary passwords. Brute-force lockout (FR-08) is enforced centrally, preventing credential stuffing attacks across all 12 federated applications simultaneously.

3. Use Case Model & Actor Hierarchy

The Use Case model maps university roles to identity governance capabilities. Actors include end-users (Students, Staff/Faculty), operational personnel (IT Helpdesk Agents), and system managers (Application Owners, IT Administrators).

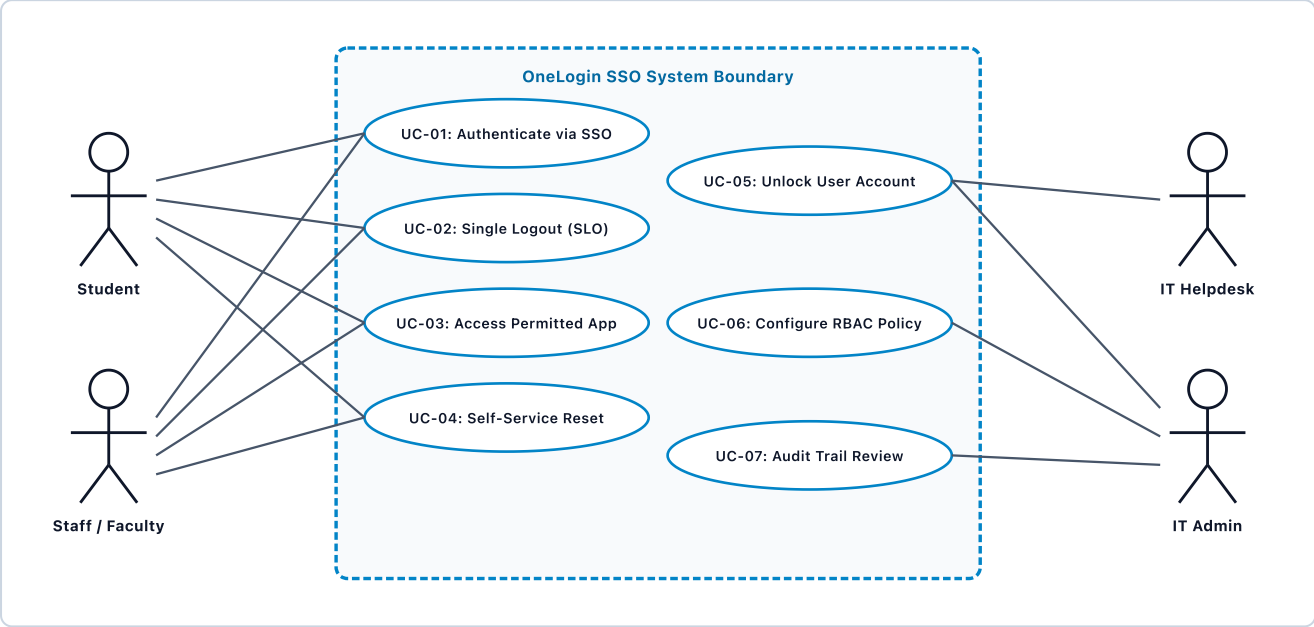


Figure 3.1: Unified Use Case Diagram Illustrating System Actors and Boundary Services.

| UC ID | Use Case Title              | Primary Actor           | SRS Traceability & Objective                                               |
|-------|-----------------------------|-------------------------|----------------------------------------------------------------------------|
| UC-01 | Authenticate via SSO        | Student, Staff, Faculty | <b>FR-01, FR-02:</b> Single central login for all permitted applications.  |
| UC-04 | Self-Service Password Reset | Student, Staff, Faculty | <b>FR-07:</b> 15-min OTP verification, cuts 75% helpdesk tickets.          |
| UC-05 | Unlock User Account         | IT Helpdesk Agent       | <b>FR-08:</b> Clear lockout flag after 5 failed login attempts.            |
| UC-07 | Configure RBAC Policy       | IT Administrator        | <b>FR-06:</b> Enforce role-application access matrix across all endpoints. |

### 4. Class Diagram & Static Structure

The static structure isolates identity providers from application implementations. Loose coupling is realized via the ApplicationAdapter interface pattern, ensuring zero IdP code changes when onboarding new applications.

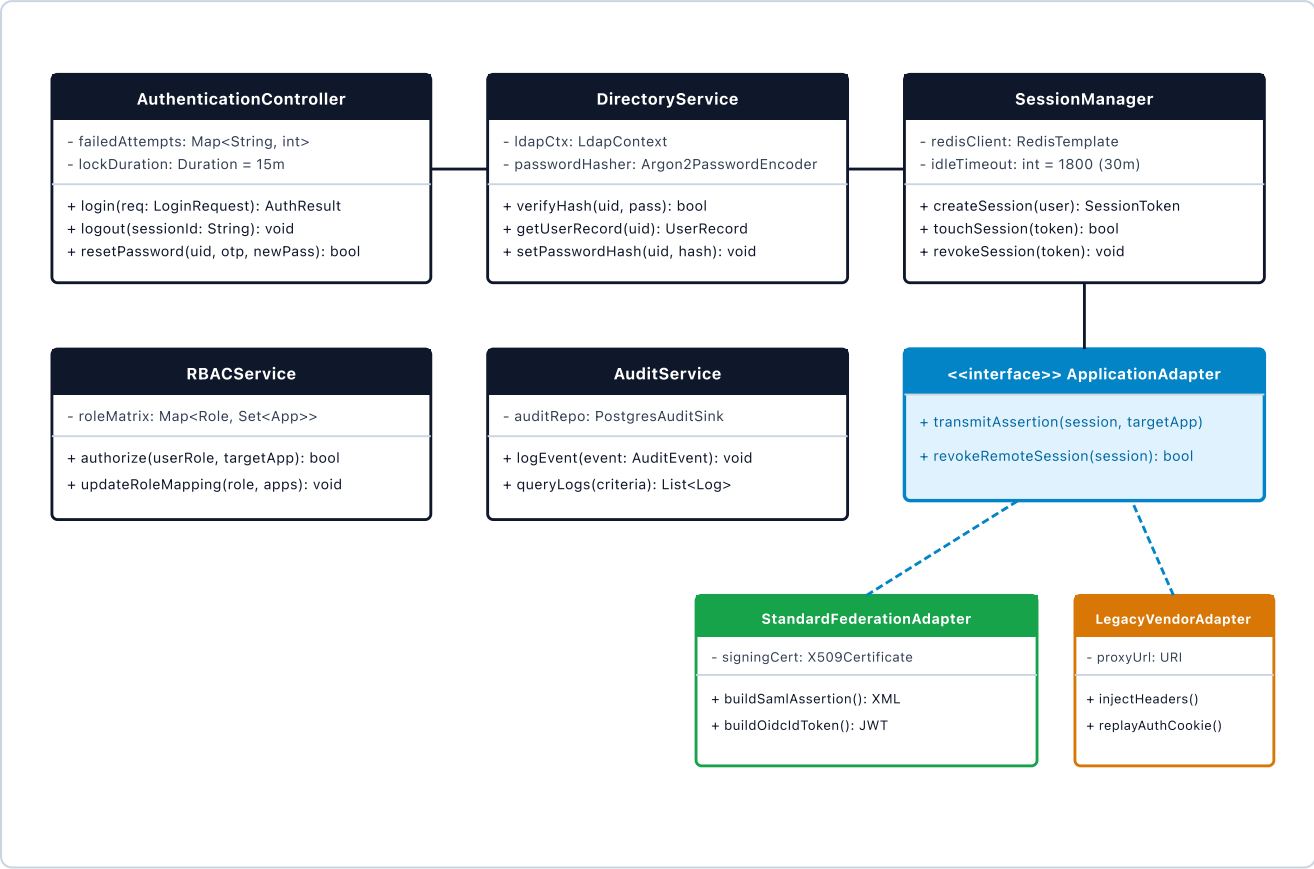


Figure 4.1: Structural Class Hierarchy Depicting Adapter Abstraction and Core Isolation.

**Design Pattern Justification:** The implementation of the *Adapter Pattern* decouples the core IdP from legacy vendor complexities. The IdP issues standardized authentication states; the concrete adapter transforms these states into SAML XML, OIDC JWT tokens, or reverse-proxy headers without polluting core login logic.

## 5. Architectural Cohesion & Loose Coupling Justification

In conformance with the Case Study no. 98 objectives, the OneLogin design enforces strong functional cohesion within internal modules while maintaining loose coupling with the 12 integrated enterprise applications.

### 5.1 Written Justification: High Functional Cohesion

Every class and subsystem within the OneLogin package is architected around the Single Responsibility Principle (SRP). A module performs exactly one bounded task, reducing internal complexity and preventing functional side-effects:

- **AuthenticationController:** Strictly manages HTTP ingress, parsing authentication requests, incrementing brute-force counters (FR-08), and enforcing the 15-minute lockout policy. It delegates credential evaluation to the directory service.
- **DirectoryService:** Possesses exclusive ownership of LDAP/SQL directory schema synchronization, salted password verification (bcrypt/Argon2 per NFR-02), and credential persistence. It contains zero session logic.
- **SessionManager:** Solely manages the state lifecycle of active sessions, idle timeout tracking (FR-09), and single-logout (SLO) broadcasts (FR-02).
- **RBACService:** Encapsulates role evaluations against the role-application access matrix (FR-06), preventing applications from altering university authorization boundaries.
- **AuditService:** Operates as an append-only event sink (FR-10), completely decoupled from authentication workflows to guarantee immutable log delivery.

### 5.2 Written Justification: Loose Coupling Across Applications

The central vulnerability of an SSO rollout is tight coupling, where IdP changes break downstream applications, or application maintenance causes IdP failures. The OneLogin design maintains loose coupling through three mechanisms:

| Decoupling Mechanism | Architectural Realization                                                               | System Benefit (NFR-06)                                                              |
|----------------------|-----------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------|
| Protocol Federation  | Standard SAML 2.0 assertions and OIDC JWT tokens over HTTPS. No direct code dependency. | Cloud applications (4) configure metadata independently; IdP core code is untouched. |
| Isolated Databases   | Applications never connect to the central LDAP/IdP user table. They consume claims.     | Zero database lock contention or cross-service schema corruption.                    |
| Adapter Abstraction  | Legacy vendor applications (3) interact through an external reverse-proxy adapter.      | Prevents proprietary vendor code from polluting the core IdP release cycle.          |

**Traceability Proof (NFR-06):** By standardizing federation claims via the `ApplicationAdapter` interface, onboarding an application requires **0 changes** to IdP source code (configuration only), satisfying the measurable target verified by test case TC-23.

## 6. Sequence Diagram: "Log In Once and Access Three Applications"

This sequence diagram specifies the interaction between the User Agent (Browser), OneLogin IdP, and three integrated systems (Cloud ERP, In-House LMS, and Cloud Email) satisfying **FR-02** and verified by **TC-03**.

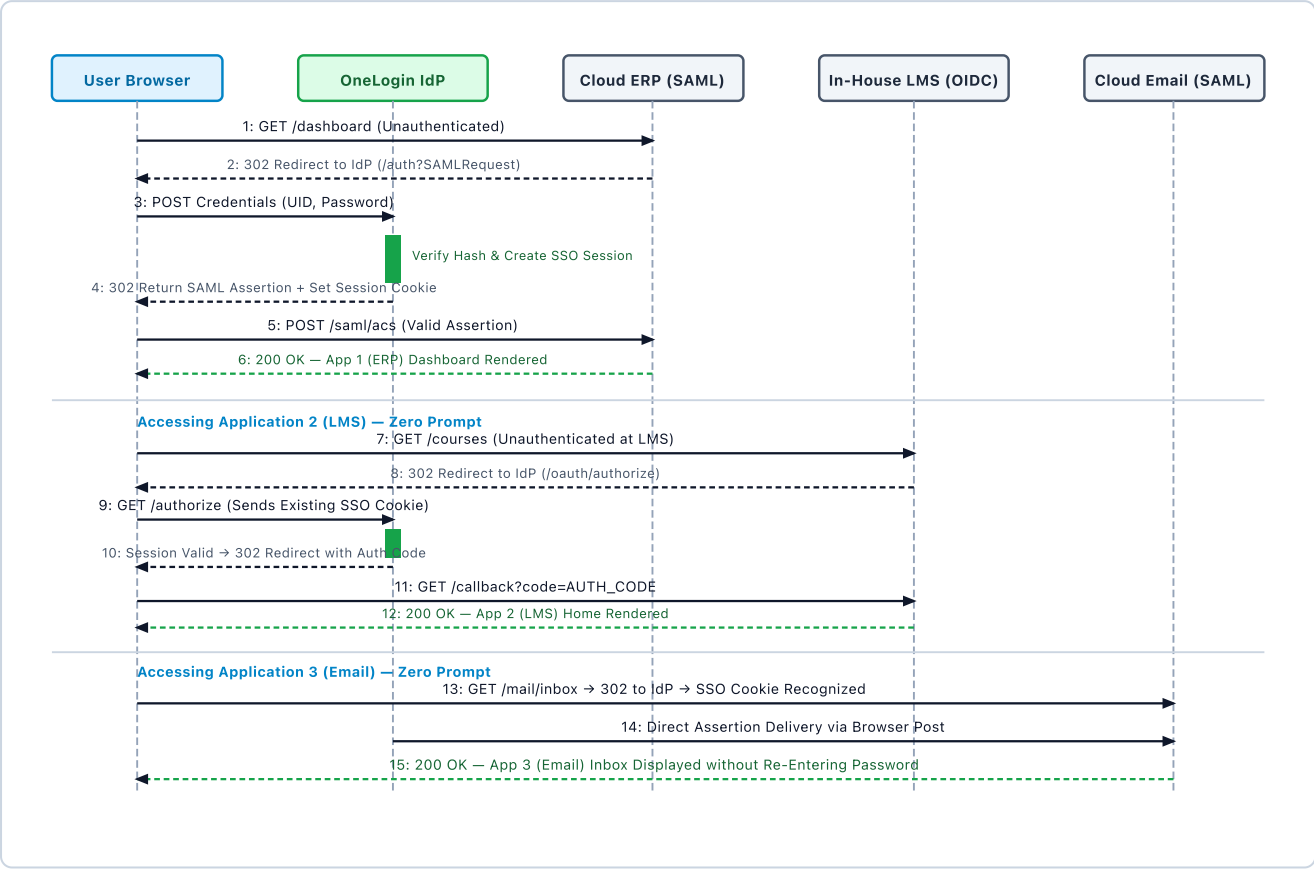


Figure 6.1: Sequence Diagram for Single Login Followed by 3 Seamless Federated Sessions.

## 7. Activity Diagram: Self-Service Password Reset (FR-07)

Detailed logic for the self-service password reset (SSPR) workflow. This design directly enables the university to eliminate 210 hours/month of IT helpdesk workload (a 75% reduction from 1,400 tickets/month down to 350).

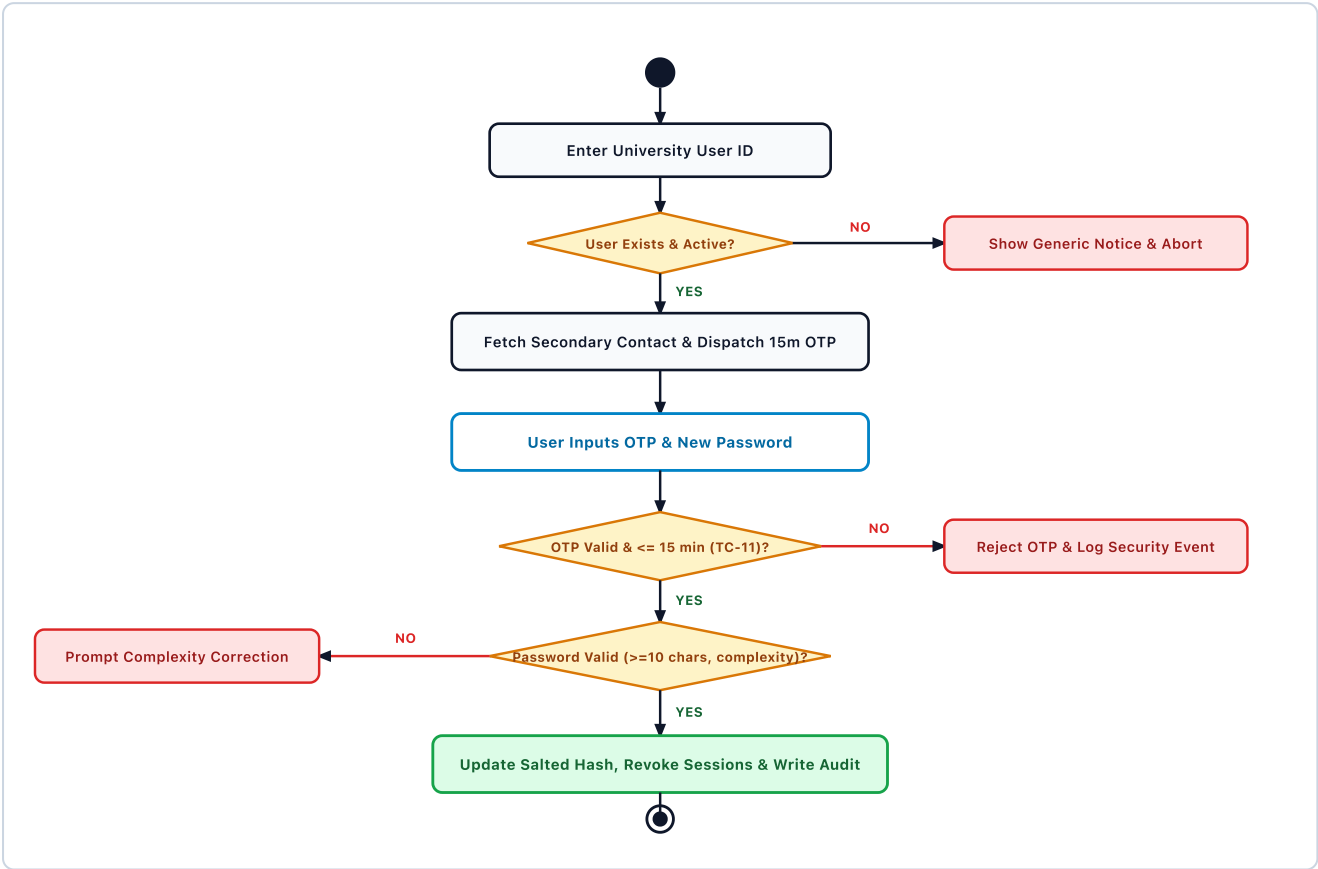


Figure 7.1: Activity Diagram for Identity Verification and Password Reset Lifecycle.

**Boundary Validation Rules:** In alignment with TC-10 and TC-11, OTP entry at minute 14.59 is accepted; OTP entry at minute 15.01 is strictly rejected. Passwords with 9 characters are rejected; 10 characters with mixed-case and digit are accepted.

8. State Machine Diagram: User Session Lifecycle

The state machine models all valid operational states of an authenticated university user session across its lifecycle, incorporating failed-login counters, idle timeout tracking, and Single Logout (SLO) broadcasts.

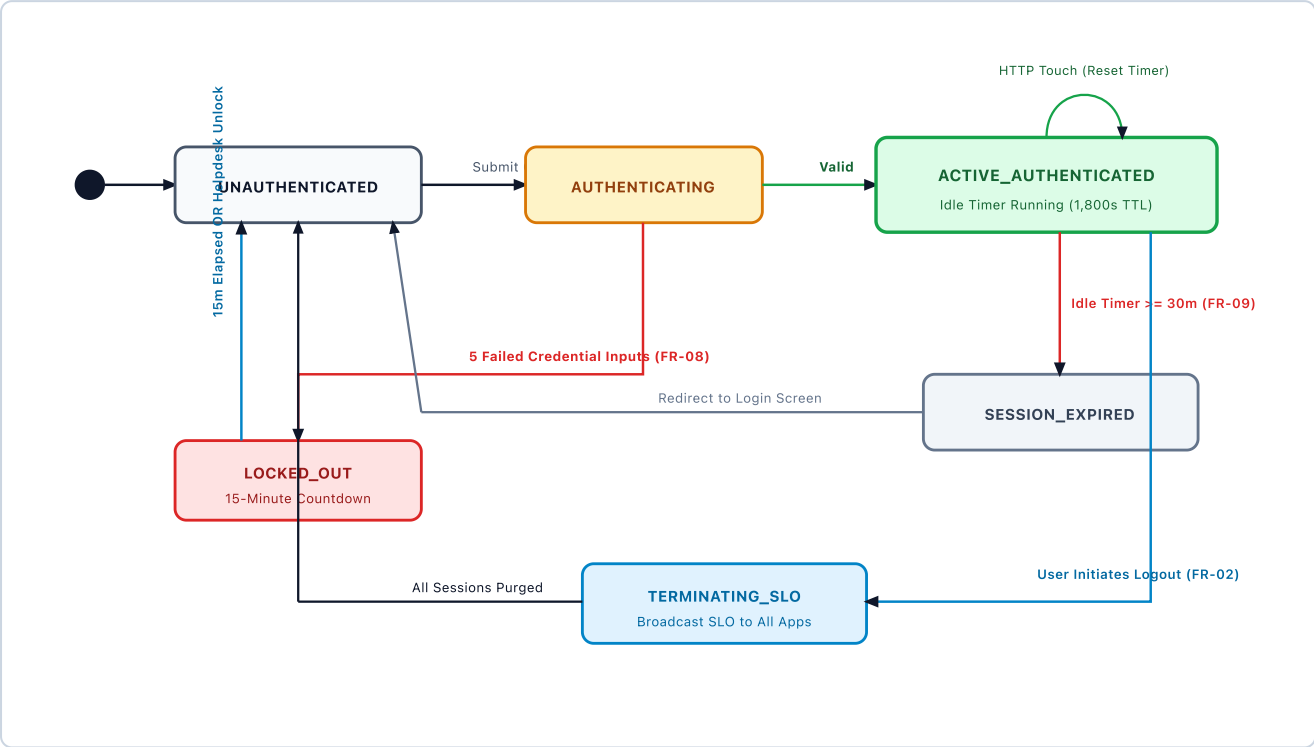


Figure 8.1: Deterministic State Transitions Governing User Authentication Lifecycles.

| Trigger / Event            | Source State         | Target State    | Operational Effect                           |
|----------------------------|----------------------|-----------------|----------------------------------------------|
| 5 Failed Credential Inputs | UNAUTHENTICATED      | LOCKED_OUT      | Enforces 15-minute wait time (FR-08).        |
| Idle Timer ≥ 30 Minutes    | ACTIVE_AUTHENTICATED | SESSION_EXPIRED | Invalidates token; redirects to IdP (FR-09). |
| Explicit Single Logout     | ACTIVE_AUTHENTICATED | TERMINATING_SLO | Revokes session across all 12 apps (FR-02).  |